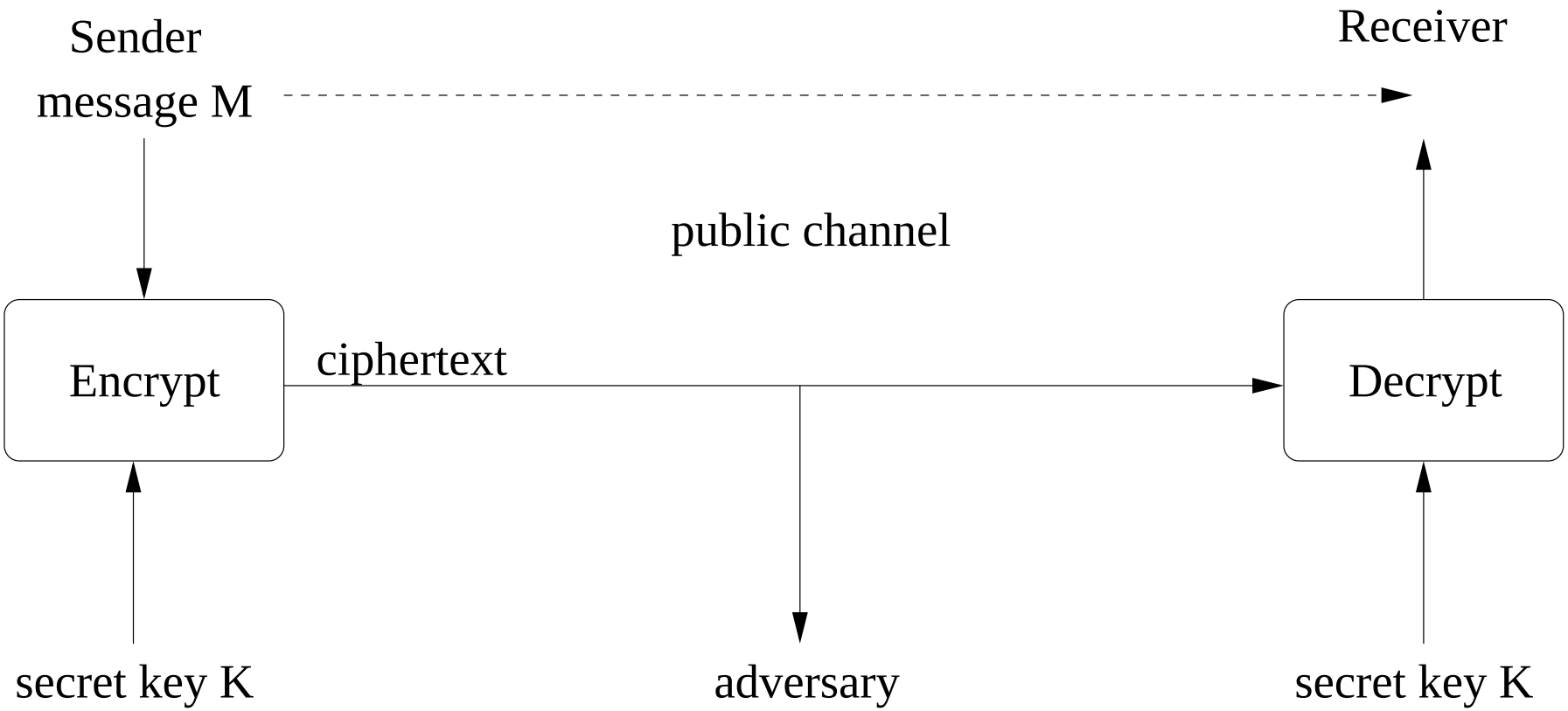
On Authentication

Palash Sarkar

Applied Statistics Unit
Indian Statistical Institute, Kolkata
India
palash@isical.ac.in

Centre for Artificial Intelligence and Robotics
Bengaluru
23rd February 2012

Symmetric Key Encryption



Security Requirement: Confidentiality

Assumption: adversary is ***passive***, i.e., does not modify the information on the channel.

Security Requirement: Confidentiality

Assumption: adversary is ***passive***, i.e., does not modify the information on the channel.

- Ciphertext should not leak information about message/key.
- Adversary may have access to previous message-ciphertext pairs.

Security Requirement: Confidentiality

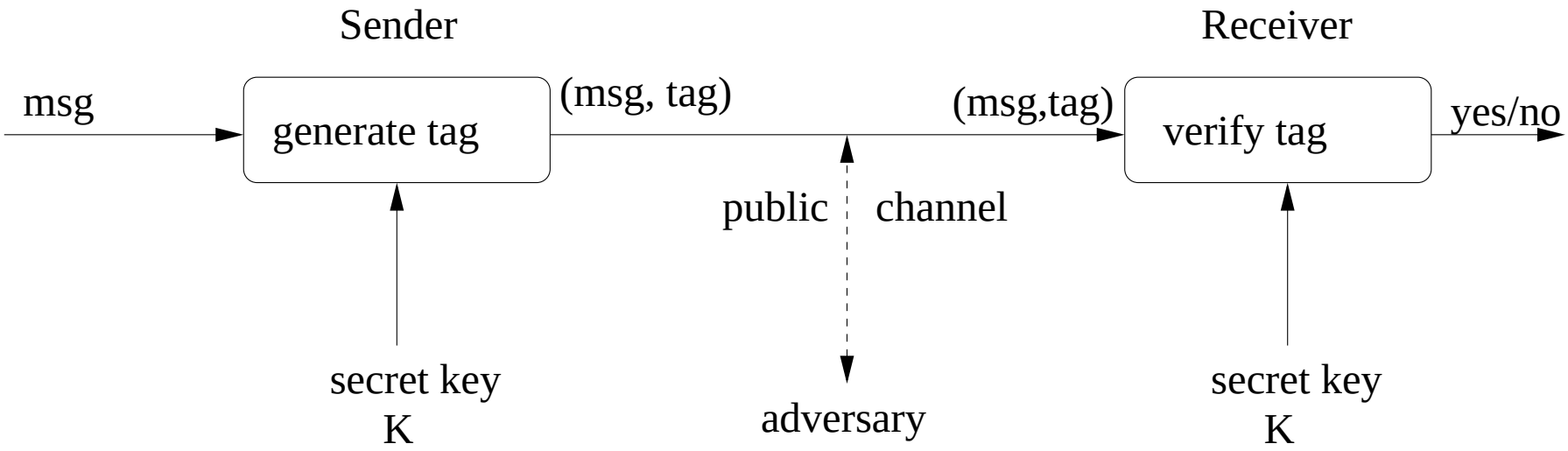
Assumption: adversary is ***passive***, i.e., does not modify the information on the channel.

- Ciphertext should not leak information about message/key.
- Adversary may have access to previous message-ciphertext pairs.

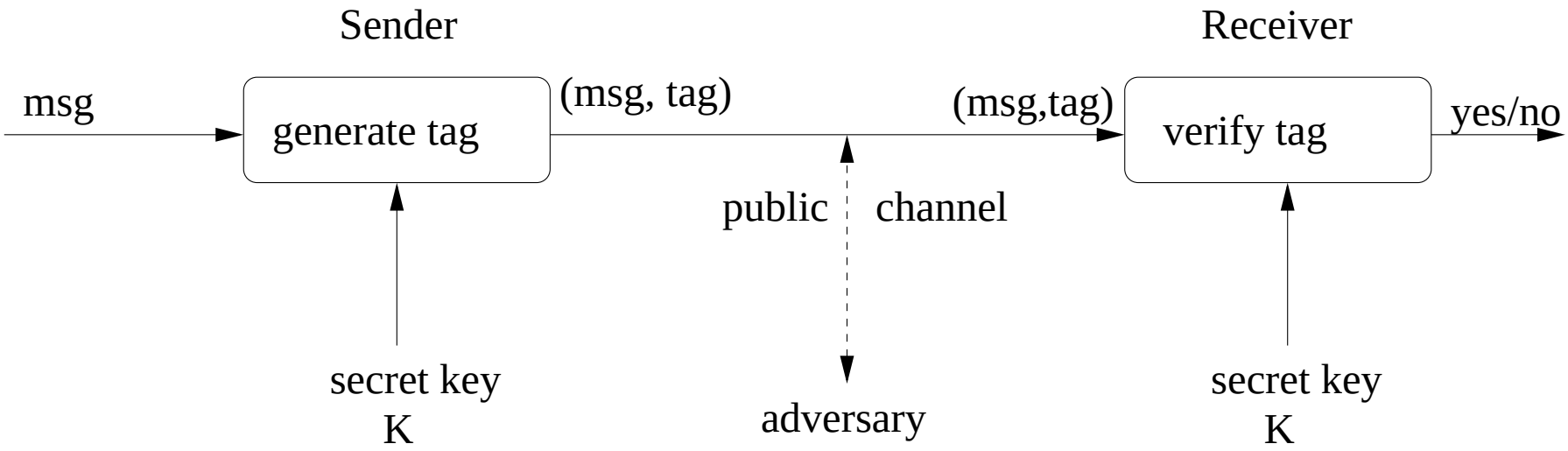
Basic attack models.

- Ciphertext only attack.
- Known plaintext attack.
- Chosen plaintext attack.
- Chosen ciphertext attack.

Symmetric Key Authentication

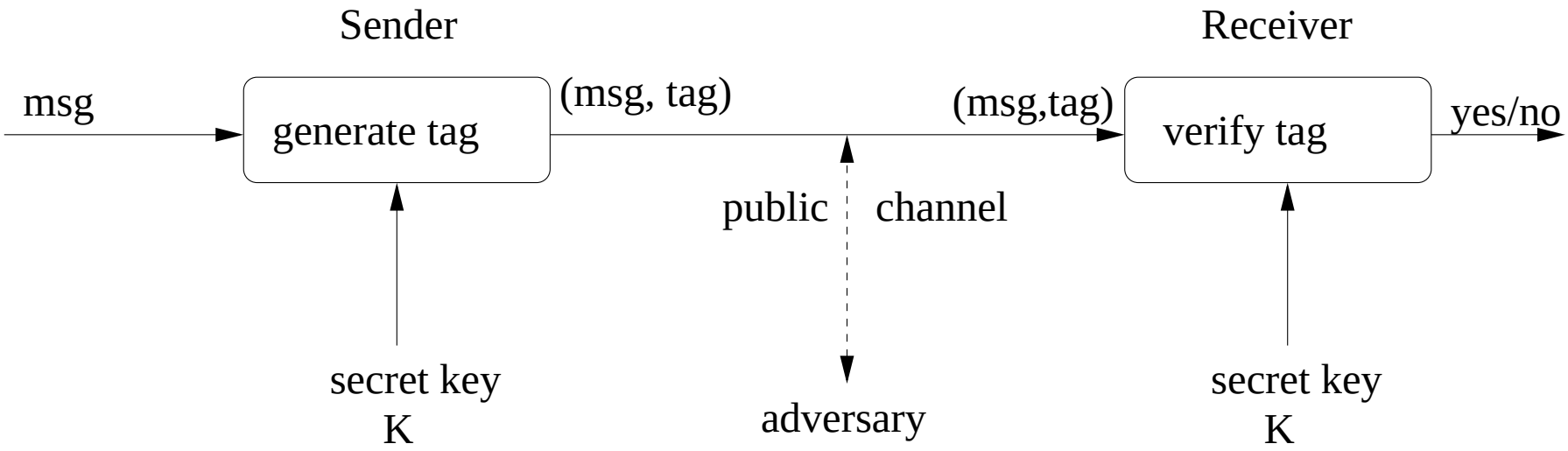


Symmetric Key Authentication



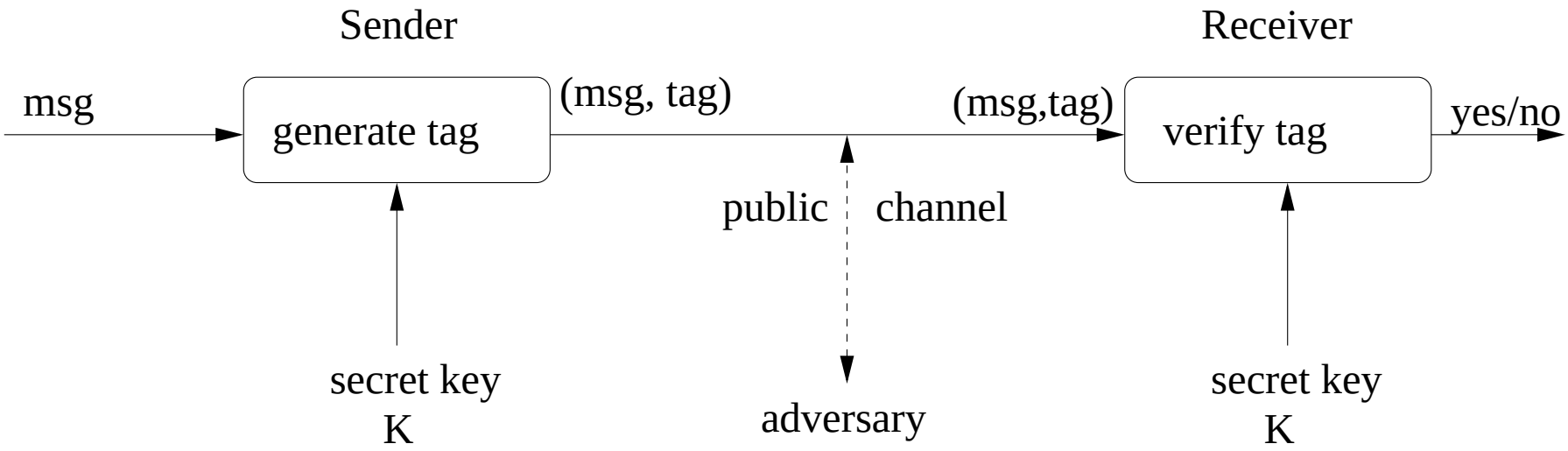
- **Adversarial Capability:** ***Active.***

Symmetric Key Authentication



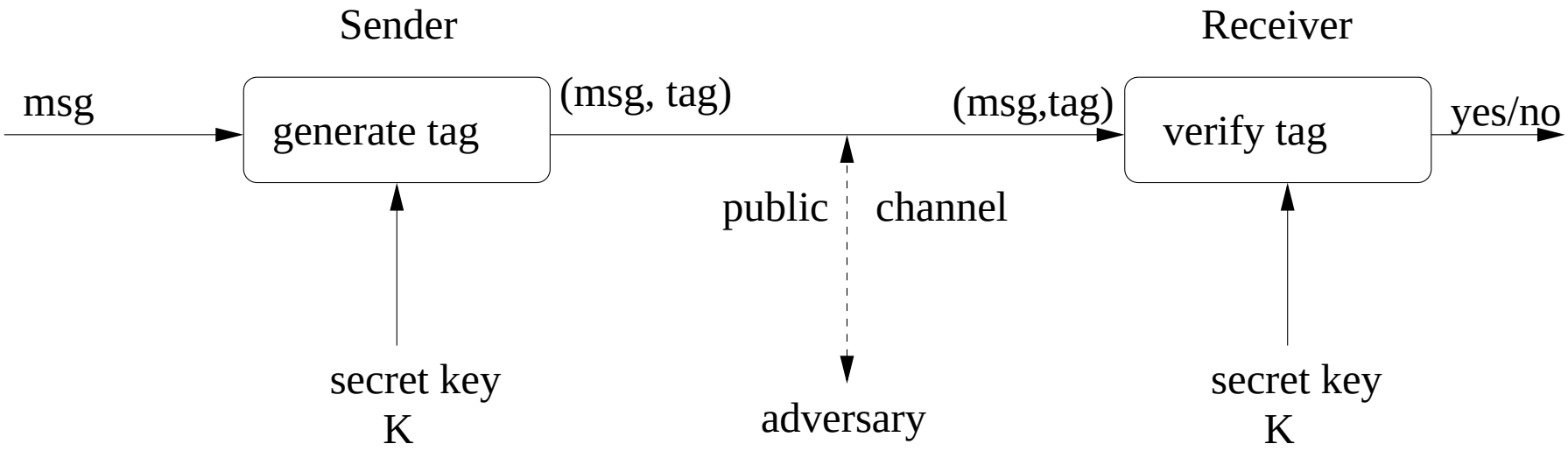
- **Adversarial Capability:** ***Active.***
  - Can listen to and modify information on the public channel.
  - Can obtain tags corresponding to chosen messages.

Symmetric Key Authentication



- **Adversarial Capability:** ***Active.***
  - Can listen to and modify information on the public channel.
  - Can obtain tags corresponding to chosen messages.
- **Adversarial goal:**
  - To make the receiver accept a msg-tag pair not generated by the sender.

Symmetric Key Authentication



- **Adversarial Capability:** ***Active.***
  - Can listen to and modify information on the public channel.
  - Can obtain tags corresponding to chosen messages.
- **Adversarial goal:**
  - To make the receiver accept a msg-tag pair not generated by the sender.
- **Adversarial Success:** a random event.
  - Measured by the probability that the receiver accepts a forgery.

One-Time Pad and Authentication

One-time pad does not provide authentication.

- Consider message: **attack at dawn**.
- Let $\mathbf{y}_1||\mathbf{y}_2$ be the ciphertext under one-time pad where,
  - $\mathbf{y}_1$ is the encryption of **attack**.
  - $\mathbf{y}_2$ is the encryption of **at dawn**.
- Then $\mathbf{y}_1$ itself is a valid forgery.
- If the adversary can successfully truncate the message, then a field unit may be lead into believing that the order is to attack immediately.

Encryption and Authentication

- Goals:
  Encryption: ‘confidentiality’ of information.
  Authentication: ‘genuineness’ of information.

Encryption and Authentication

- Goals:
  Encryption: ‘confidentiality’ of information.
  Authentication: ‘genuineness’ of information.
- Adversary:
  Encryption: passive.
  Authentication: active.

Encryption and Authentication

- Goals:
  Encryption: ‘confidentiality’ of information.
  Authentication: ‘genuineness’ of information.
- Adversary:
  Encryption: passive.
  Authentication: active.
- Encryption does not guarantee security against an adversary who ‘tampers’ the ciphertext.
- Authentication sends the message in the clear and does not provide any confidentialty.

Encryption and Authentication

- Goals:
  Encryption: ‘confidentiality’ of information.
  Authentication: ‘genuineness’ of information.
- Adversary:
  Encryption: passive.
  Authentication: active.
- Encryption does not guarantee security against an adversary who ‘tampers’ the ciphertext.
- Authentication sends the message in the clear and does not provide any confidentialty.

Authenticated Encryption: achieves to provide both confidentiality and authentication.

Queen Mary: An Example from History

The imprisoned queen used encryption to communicate with Anthony Babington, the head of a group of conspirators who wanted to remove Queen Elizabeth.

Queen Mary: An Example from History

The imprisoned queen used encryption to communicate with Anthony Babington, the head of a group of conspirators who wanted to remove Queen Elizabeth.

The encryption system was broken by Thomas Phelippes who got to know about Babington's proposal to Mary to assasinate Elizabeth.

Mary's response to Babington supporting this move was also cryptanalysed.

Queen Mary: An Example from History

The imprisoned queen used encryption to communicate with Anthony Babington, the head of a group of conspirators who wanted to remove Queen Elizabeth.

The encryption system was broken by Thomas Phelippes who got to know about Babington's proposal to Mary to assasinate Elizabeth.

Mary's response to Babington supporting this move was also cryptanalysed.

Phelippes added a forged note to Mary's letter requesting Babington to provide her with the names of all the conspirators.

Queen Mary: An Example from History

The imprisoned queen used encryption to communicate with Anthony Babington, the head of a group of conspirators who wanted to remove Queen Elizabeth.

The encryption system was broken by Thomas Phelippes who got to know about Babington's proposal to Mary to assasinate Elizabeth.

Mary's response to Babington supporting this move was also cryptanalysed.

Phelippes added a forged note to Mary's letter requesting Babington to provide her with the names of all the conspirators.

- A classic example of an active attack.
- Just breaking the encryption system would not have provided the names of the conspirators.
- Perhaps, it was thought that encryption implied authenticity.

Authentication: A Simple Scheme

Let $\{H_\tau\}_{\tau \in \mathcal{T}}$ be a family of functions such that

- for each τ, $H_\tau : \mathcal{M} \to \{0,1\}^n$;
- for a uniform random τ, and any two distinct M, M',

$$\Pr[H_\tau(M) = H_\tau(M')] \leq \varepsilon.$$

Authentication: A Simple Scheme

Let $\{H_\tau\}_{\tau \in \mathcal{T}}$ be a family of functions such that

- for each τ, $H_\tau : \mathcal{M} \rightarrow \{0,1\}^n$;
- for a uniform random τ, and any two distinct M, M',

$$\Pr[H_\tau(M) = H_\tau(M')] \leq \varepsilon.$$

Let $E_K : \{0,1\}^n \rightarrow \{0,1\}^n$ be a block cipher.

Authentication: A Simple Scheme

Let $\{H_\tau\}_{\tau \in \mathcal{T}}$ be a family of functions such that

- for each τ, $H_\tau : \mathcal{M} \rightarrow \{0,1\}^n$;
- for a uniform random τ, and any two distinct M, M',

$$\Pr[H_\tau(M) = H_\tau(M')] \leq \varepsilon.$$

Let $E_K : \{0,1\}^n \rightarrow \{0,1\}^n$ be a block cipher.

Tag generation:

$$M \mapsto (M, \text{tag})$$

where $\text{tag} = E_K(H_\tau(M))$.

Construction of Suitable $\{H_\tau\}_{\tau \in \mathcal{T}}$

Let $\mathcal{T} = GF(2^n)$; $\mathcal{M} = GF(2^n)^s$, i.e.,

- τ is an n-bit string;
- a message consists of s n-bit strings.

Write $M = (M_0, \ldots, M_{s-1})$. Then

$$H_\tau(M) = M_0 \tau^{s-1} \oplus M_1 \tau^{s-2} \oplus \cdots \oplus M_{s-2}\tau \oplus M_{s-1}.$$

Easy to show that for uniform random τ and $M_1 \neq M_2$,

$$\Pr[H_\tau(M_1) = H_\tau(M_2)] \leq \frac{s-1}{2^n}.$$

Constructions of Practical Authentication Schemes

Block-cipher based:

- Only a block cipher.
- A block cipher and a hash function with provably low differential probabilities (almost XOR-universal).
- The underlying assumption in both cases is that the block cipher is a strong pseudo-random permutation.

Constructions of Practical Authentication Schemes

Block-cipher based:

- Only a block cipher.
- A block cipher and a hash function with provably low differential probabilities (almost XOR-universal).
- The underlying assumption in both cases is that the block cipher is a strong pseudo-random permutation.

Stream-cipher based:

- A stream cipher with IV and an almost-XOR universal hash function.
- The underlying assumption is that the stream cipher with IV is a PRF.

Constructions of Practical Authentication Schemes

Block-cipher based:

- Only a block cipher.
- A block cipher and a hash function with provably low differential probabilities (almost XOR-universal).
- The underlying assumption in both cases is that the block cipher is a strong pseudo-random permutation.

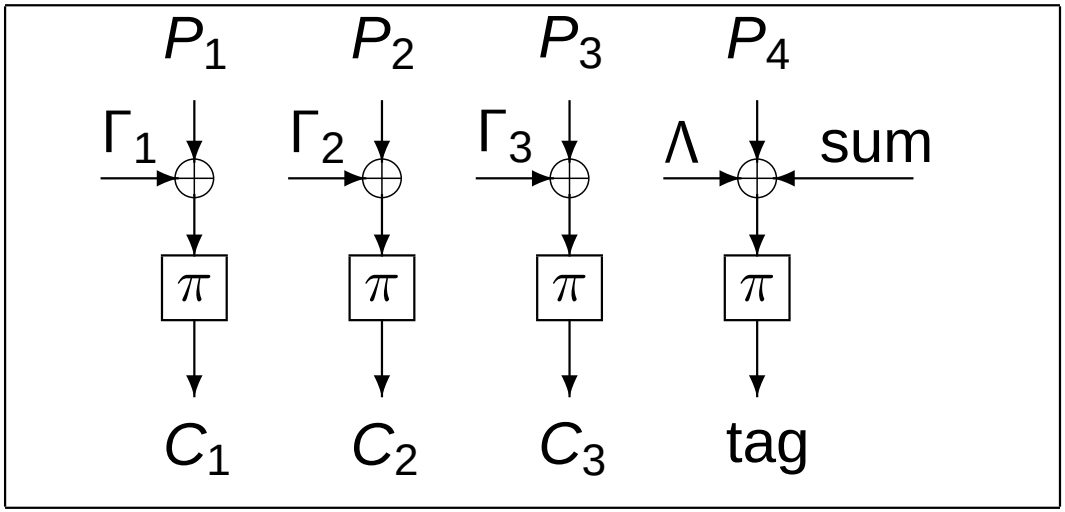
Stream-cipher based:

- A stream cipher with IV and an almost-XOR universal hash function.
- The underlying assumption is that the stream cipher with IV is a PRF.

Hash-function based:

- Requires a suitable assumption on the underlying hash function.

iPMAC: A Block-Cipher Based Scheme



- $\gamma = \pi(\text{str})$; str is a fixed string.
- $\Gamma_i = \phi_\gamma(i)$;
- $\Lambda = 0^n$ if the last block is full and $\Lambda = \phi_\gamma(4)$ if the last block has been padded;
- sum $= C_1 \oplus C_2 \oplus C_3$.

Masking Functions

$\psi : \mathbb{F}_{2^n} \rightarrow \mathbb{F}_{2^n}$ be linear and $\phi_\beta(i) = \psi^i(\beta)$.

Masking Functions

$\psi : \mathbb{F}_{2^n} \to \mathbb{F}_{2^n}$ be linear and $\phi_\beta(i) = \psi^i(\beta)$.

ϕ is a proper masking function if

- $\Pr[\phi_\beta(k) = \alpha] = 1/2^n$.
- $\Pr[\phi_\beta(k_1) \oplus \phi_\beta(k_2) = \alpha] = 1/2^n$.
- $\Pr[\phi_{\beta_1}(k_1) \oplus \phi_{\beta_2}(k_2) = \alpha] = 1/(2^n - 1)$.

for any α; non-negative integer k; integers k_1, k_2; uniform random β; uniform random (β_1, β_2) chosen without replacement;

Masking Functions

$\psi : \mathbb{F}_{2^n} \to \mathbb{F}_{2^n}$ be linear and $\phi_\beta(i) = \psi^i(\beta)$.

ϕ is a proper masking function if

- $\Pr[\phi_\beta(k) = \alpha] = 1/2^n$.
- $\Pr[\phi_\beta(k_1) \oplus \phi_\beta(k_2) = \alpha] = 1/2^n$.
- $\Pr[\phi_{\beta_1}(k_1) \oplus \phi_{\beta_2}(k_2) = \alpha] = 1/(2^n - 1)$.

for any α; non-negative integer k; integers k_1, k_2; uniform random β; uniform random (β_1, β_2) chosen without replacement;
Instantiations.

- Powering-up: $\phi : i \mapsto u^i \beta \bmod \tau(u)$.
- Faster: using tower field representation of $\mathbb{F}_{2^n}$.

Security of iPMAC

$$\text{iPMAC} = \pi \circ \text{iPHASH}$$

Security of iPMAC

$$\text{iPMAC} = \pi \circ \text{iPHASH}$$

iPHASH.

- produces the input just before the final π invocation.
- collision probabilities: at most $\max(m, m')/2^n$;
- self-disjoint probabilities: at most $2m/2^n$;
- pairwise-disjoint probabilities: at most $(m + m')/2^n$;

Security of iPMAC

$$\text{iPMAC} = \pi \circ \text{iPHASH}$$

iPHASH.

- produces the input just before the final π invocation.
- collision probabilities: at most $\max(m, m')/2^n$;
- self-disjoint probabilities: at most $2m/2^n$;
- pairwise-disjoint probabilities: at most $(m + m')/2^n$;

Theorem.

$$\mathbf{Adv}^{\text{prf}}_{\text{iPMAC}}(q, \sigma) \leq \frac{(7q + 2)\sigma}{2^n}.$$

Efficiency of iPMAC

The ‘i’ in iPMAC **denotes improvement over** PMAC **(Rogaway)**

Efficiency of iPMAC

The 'i' in iPMAC **denotes improvement over** PMAC **(Rogaway)**

- Easily reconfigurable: simply changing the field representation changes the algorithm; PMAC requires a design stage discrete log computation.
- Faster masking in software using tower field representation of $\mathbb{F}_{2^n}$.

Stream-Cipher Based Authentication Scheme

$\mathrm{SC}_K(IV)$: stream cipher supporting an IV.

$\mathrm{Hash}_\tau(M)$: almost XOR-universal hash function.

Stream-Cipher Based Authentication Scheme

$\mathrm{SC}_K(IV)$: stream cipher supporting an IV.

$\mathrm{Hash}_\tau(M)$: almost XOR-universal hash function.

MAC_K(nonce N, msg M):

$(R, \tau) = \mathrm{SC}_K(N)$;

$\mathrm{tag} = \mathrm{Hash}_\tau(M) \oplus R$.

Stream-Cipher Based Authentication Scheme

$\mathrm{SC}_K(IV)$: stream cipher supporting an IV.

$\mathrm{Hash}_\tau(M)$: almost XOR-universal hash function.

$\mathrm{MAC}_K(\text{nonce } N, \text{msg } M)$:

$(R, \tau) = \mathrm{SC}_K(N)$;

$\text{tag} = \mathrm{Hash}_\tau(M) \oplus R$.

A formal security analysis of this scheme is available.

Authenticated Encryption

- Usually both confidentiality and authentication are required simultaneously.
  - Confidentiality ensures privacy of the communication.
  - Authentication ensures integrity of the message.

Authenticated Encryption

- Usually both confidentiality and authentication are required simultaneously.
  - Confidentiality ensures privacy of the communication.
  - Authentication ensures integrity of the message.
- Internet packets.
  - Confidentiality and authentication of the body (data).

Authenticated Encryption

- Usually both confidentiality and authentication are required simultaneously.
  - Confidentiality ensures privacy of the communication.
  - Authentication ensures integrity of the message.
- Internet packets.
  - Confidentiality and authentication of the body (data).
  - Header cannot be encrypted, since then the packet cannot be forwarded by intermediate routers.

Authenticated Encryption

- Usually both confidentiality and authentication are required simultaneously.
  - Confidentiality ensures privacy of the communication.
  - Authentication ensures integrity of the message.
- Internet packets.
  - Confidentiality and authentication of the body (data).
  - Header cannot be encrypted, since then the packet cannot be forwarded by intermediate routers.
  - Header has to be authenticated.

Authenticated Encryption

- Usually both confidentiality and authentication are required simultaneously.
  - Confidentiality ensures privacy of the communication.
  - Authentication ensures integrity of the message.
- Internet packets.
  - Confidentiality and authentication of the body (data).
  - Header cannot be encrypted, since then the packet cannot be forwarded by intermediate routers.
  - Header has to be authenticated.
  - Gives rise to authenticated encryption with associated data. (header=associated data)

Basic Primitives for Constructing AEAD Schemes

- Block cipher with or without an almost XOR-universal hash function.
  - Underlying assumption: the block cipher is an SPRP.

Basic Primitives for Constructing AEAD Schemes

- Block cipher with or without an almost XOR-universal hash function.
  - Underlying assumption: the block cipher is an SPRP.
- Stream cipher with IV and an almost XOR-universal hash function.
  - Underlying assumption: the stream cipher with IV is a PRF.

Two-Pass AE Schemes

- First pass over the message to encrypt the message.
- Second pass over the ciphertext to generate a tag.

Two-Pass AE Schemes

- First pass over the message to encrypt the message.
- Second pass over the ciphertext to generate a tag.
- Textbook scheme: first pass: counter; second pass: CBC; cost per block: **2[BC]**.
- Getting things right is non-trivial.

Two-Pass AE Schemes

- First pass over the message to encrypt the message.
- Second pass over the ciphertext to generate a tag.
- Textbook scheme: first pass: counter; second pass: CBC; cost per block: **2[BC]**.
- Getting things right is non-trivial.
- Concrete scheme:
  - GCM: standardized by NIST (USA).
    first pass: counter; second pass: universal hash
    cost per block: **1[BC]+1[M]**.

Two-Pass AE Schemes

- First pass over the message to encrypt the message.
- Second pass over the ciphertext to generate a tag.
- Textbook scheme: first pass: counter; second pass: CBC; cost per block: **2[BC]**.
- Getting things right is non-trivial.
- Concrete scheme:
  - GCM: standardized by NIST (USA).
    first pass: counter; second pass: universal hash
    cost per block: **1[BC]+1[M]**.

Efficient single-pass AE schemes without patent claims are known.

PAE: Block-Cipher Based AE Scheme

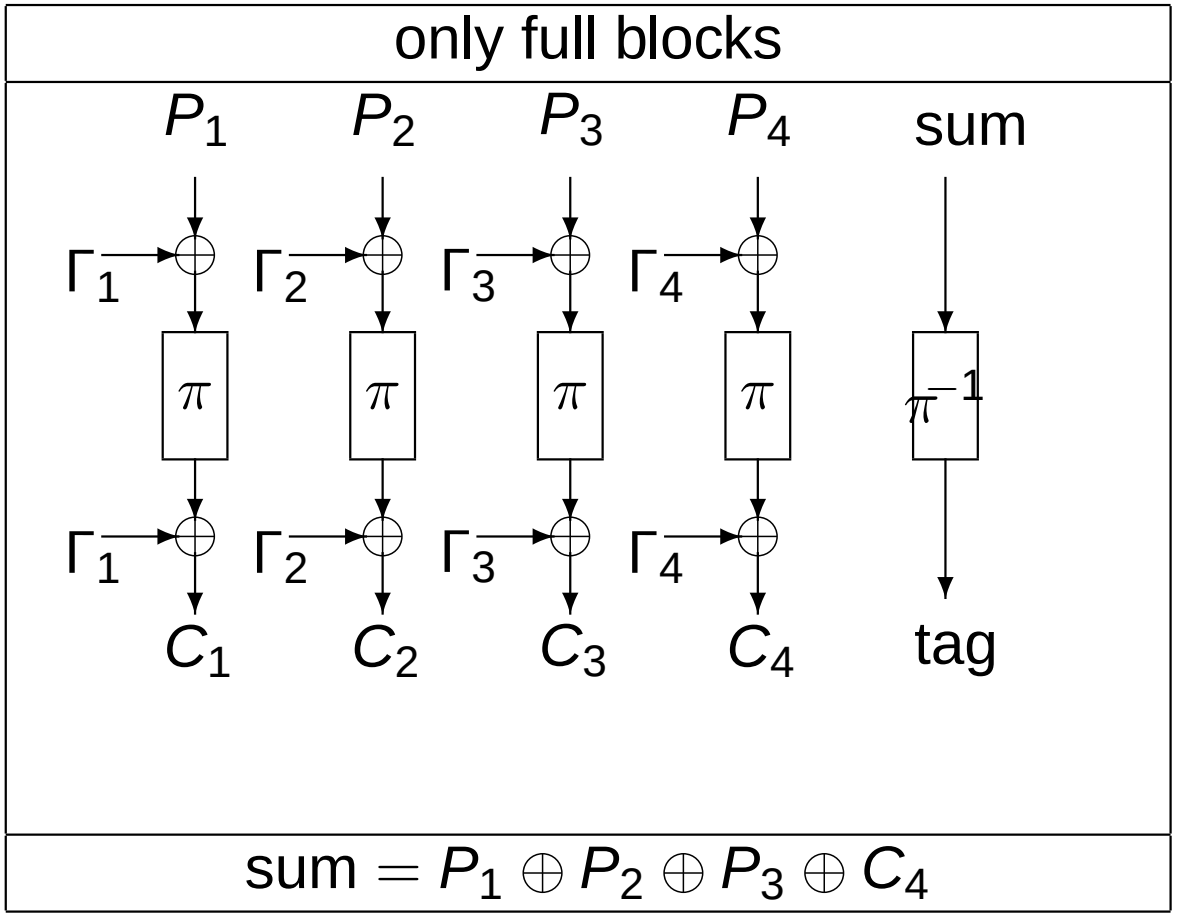


Figure: Encryption using PAE: $\gamma = \pi^{-1}(N)$; $\Gamma_i = \phi_\gamma(i)$.

PAE (Contd.)

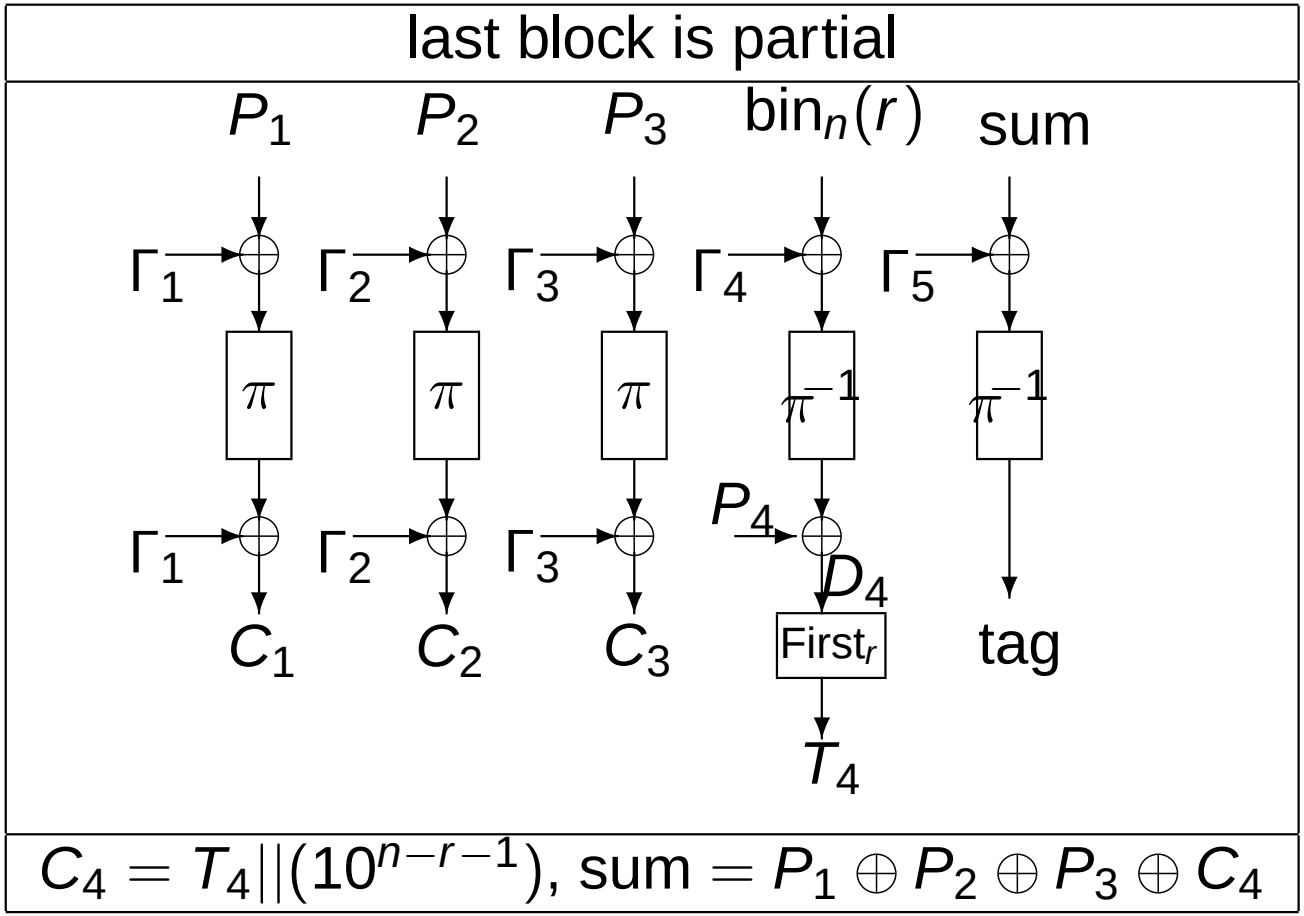


Figure: Encryption using PAE: $\gamma = \pi^{-1}(N)$; $\Gamma_i = \phi_\gamma(i)$.

PAE (Contd.)

- $\pi()$ is $E_K()$.
- $\pi^{-1}()$ is $D_K() = E_K^{-1}()$.
- N is the nonce (fresh for each message).

PAE (Contd.)

- $\pi()$ is $E_K()$.
- $\pi^{-1}()$ is $D_K() = E_K^{-1}()$.
- N is the nonce (fresh for each message).
- $\phi_\gamma(i) = \psi^i(\gamma)$ where

$$\psi : \mathbb{F}_{2^n} \rightarrow \mathbb{F}_{2^n}.$$

  - The minimal polynomial of ψ over $\mathbb{F}_2$ is a primitive polynomial.
  - The "powering up" operation used in OCB is a special case.
  - Faster implementations in software can be obtained using a tower field representation of $\mathbb{F}_{2^n}$.

Privacy of PAE

Theorem (Privacy).

$$\mathbf{Adv}^{\mathrm{priv}}_{\mathrm{PAE}}(q, \sigma) \leq \frac{2(\sigma + 2q)^2}{2^n}.$$

Consequently,

$$\mathbf{Adv}^{\mathrm{priv}}_{\mathrm{PAE}\,\mathrm{main}}(q, \sigma) \leq \frac{2(\sigma + 2q)^2}{2^n}.$$

Privacy of PAE

Theorem (Privacy).

$$\mathbf{Adv}^{\mathrm{priv}}_{\mathrm{PAE}}(q, \sigma) \leq \frac{2(\sigma + 2q)^2}{2^n}.$$

Consequently,

$$\mathbf{Adv}^{\mathrm{priv}}_{\mathrm{PAE}^{\mathrm{main}}}(q, \sigma) \leq \frac{2(\sigma + 2q)^2}{2^n}.$$

- Internal collisions: equality of internal random variables.
- Proof reduces to showing that the probability of internal collisions is small.

Authentication of PAE

- $\widetilde{\text{PAE}}_\pi$ (the associated authentication function) is equal to $\text{miPMAC}_{\pi^{-1}}$.
- $\text{miPMAC}_{\pi^{-1}}$ is a modified version of iPMAC and has the same security bound.
- PAE was designed so as to achieve this equality.

Authentication of PAE

- $\widetilde{\text{PAE}}_\pi$ (the associated authentication function) is equal to $\text{miPMAC}_{\pi^{-1}}$.
- $\text{miPMAC}_{\pi^{-1}}$ is a modified version of iPMAC and has the same security bound.
- PAE was designed so as to achieve this equality.

For every $N \in \{0,1\}^n$ and binary string C, with $\text{len}(C) \geq 0$,

$$\widetilde{\text{PAE}}_\pi(N, C) = \text{miPMAC}_{\pi^{-1}}(N, C).$$

Authentication of PAE

- $\widetilde{\text{PAE}}_\pi$ (the associated authentication function) is equal to $\text{miPMAC}_{\pi^{-1}}$.
- $\text{miPMAC}_{\pi^{-1}}$ is a modified version of iPMAC and has the same security bound.
- PAE was designed so as to achieve this equality.

For every $N \in \{0,1\}^n$ and binary string C, with $\text{len}(C) \geq 0$,

$$\widetilde{\text{PAE}}_\pi(N, C) = \text{miPMAC}_{\pi^{-1}}(N, C).$$

Consequently,

$$\mathbf{Adv}^{\text{prf}}_{\widetilde{\text{PAE}}}(q, \sigma) = \mathbf{Adv}^{\text{prf}}_{\text{miPMAC}}(q, \sigma) \leq \frac{\sigma(7q + 2)}{2^n}.$$

Authentication of PAE

- $\widetilde{\text{PAE}}_\pi$ (the associated authentication function) is equal to $\text{miPMAC}_{\pi^{-1}}$.
- $\text{miPMAC}_{\pi^{-1}}$ is a modified version of iPMAC and has the same security bound.
- PAE was designed so as to achieve this equality.

For every $N \in \{0,1\}^n$ and binary string C, with $\text{len}(C) \geq 0$,

$$\widetilde{\text{PAE}}_\pi(N, C) = \text{miPMAC}_{\pi^{-1}}(N, C).$$

Consequently,

$$\mathbf{Adv}^{\text{prf}}_{\widetilde{\text{PAE}}}(q, \sigma) = \mathbf{Adv}^{\text{prf}}_{\text{miPMAC}}(q, \sigma) \leq \frac{\sigma(7q+2)}{2^n}.$$

Authentication of PAE:

$$\mathbf{Adv}^{\text{aeauth}}_{t\text{-PAE}}(q, \sigma) \leq \frac{1}{2^t} + \frac{2(\sigma+2q)^2}{2^n} + \frac{\sigma(7q+2)}{2^n}.$$

Advantages Over OCB (and Others)

- Easy to change the masking functions.
  - Simply choose another suitable ϕ.
  - No discrete log computation required.
  - Easily defined for $n = 256$.

Advantages Over OCB (and Others)

- Easy to change the masking functions.
  - Simply choose another suitable ϕ.
  - No discrete log computation required.
  - Easily defined for $n = 256$.
- Faster masking in software.
  - Use of tower field representation to realise ϕ.

Advantages Over OCB (and Others)

- Easy to change the masking functions.
  - Simply choose another suitable ϕ.
  - No discrete log computation required.
  - Easily defined for $n = 256$.
- Faster masking in software.
  - Use of tower field representation to realise ϕ.
- The decryption algorithm of PAE does not require $E_K()$.
  - Smaller size hardware module for decryption.
  - Useful in situations where encrypted instructions are only sent to lower-level recipients.

Advantages Over OCB (and Others)

- Easy to change the masking functions.
  - Simply choose another suitable ϕ.
  - No discrete log computation required.
  - Easily defined for $n = 256$.
- Faster masking in software.
  - Use of tower field representation to realise ϕ.
- The decryption algorithm of PAE does not require $E_K()$.
  - Smaller size hardware module for decryption.
  - Useful in situations where encrypted instructions are only sent to lower-level recipients.
- Simpler description.
  - Leads to a direct proof of security.

Stream-Cipher Based AE Scheme

$\mathrm{SC}_K(IV)$: stream cipher supporting an IV.

$\mathrm{Hash}_\tau(M)$: almost XOR-universal hash function.

Stream-Cipher Based AE Scheme

$\mathrm{SC}_K(IV)$: stream cipher supporting an IV.

$\mathrm{Hash}_\tau(M)$: almost XOR-universal hash function.

AE-1.$\mathrm{Encrypt}_{K,\tau}$(nonce N, msg M):

$(R, Z) = \mathrm{SC}_K(N)$;

$C = M \oplus Z$;

$\mathrm{tag} = \mathrm{Hash}_\tau(C) \oplus R$.

Stream-Cipher Based AE Scheme

$\mathrm{SC}_K(IV)$: stream cipher supporting an IV.

$\mathrm{Hash}_\tau(M)$: almost XOR-universal hash function.

AE-1.$\mathrm{Encrypt}_{K,\tau}$(nonce N, msg M):

$(R, Z) = \mathrm{SC}_K(N)$;
$C = M \oplus Z$;
$\mathrm{tag} = \mathrm{Hash}_\tau(C) \oplus R$.

- There are three other schemes suitable for use with different options for Hash.
- Formal security analyses of all three schemes are available.

Summary

- Achieving authentication is a security goal which is distinct from encryption or confidentiality.
- Idea of practical authentication schemes.
- Combination of authentication and encryption.
- Idea of practical AE schemes.

Thank you for your attention!